

Q FM 8+

...

Operation Follow Me

모의해킹 기반 FM 8+ 정보보호 진단

팔로팔로미

김혜미, 조경익, 김유선, 이찬근, 정슬기



목 차



- | | |
|-----------------------------|------------------|
| 01 프로젝트 일정 / 개요 | 06 네트워크 환경 구성도 |
| 02 프로젝트 팀 구성 및 역할 | 07 악성코드 분석 결과 |
| 03 프로젝트 수행절차 및 방법 | 08 모의 해킹 결과 |
| 04 기술 스택 및 환경 구성 | 09 기업 정보보호 점검 결과 |
| 05 비즈니스 흐름도 / FM 8+ 인프라 구성도 | 10 자체 평가 의견 |

01

프로젝트 일정 / 개요

1

프로젝트 일정

07.23 ~ 08.05 · 단계별 타임라인

2

프로젝트 개요

Operation Follow Me · 팀·핵심기술

3

선정 배경 및 최종 목표

SKT HSS 사고 · End-to-End 진단 체계

[illegible]



프로젝트 개요



프로젝트명	Operation Follow Me (모의해킹 기반 FM 8+ 정보보호 진단)
진행기간	2026.07.23 ~ 2026.08.04
팀 구성	8팀 팔로팔로미 김혜미, 조경익, 김유선, 이찬근, 정슬기
핵심기술	Firewall(pfSense), IDS·IPS(Suricata), WAF(ModSecurity), SIEM(ELK Stack)



프로젝트 선정배경 및 최종목표



선정배경

■ 2025년 4월, SKT HSS 해킹 사고

987일간 잠복 후 유심 인증정보 **2,696만 건** 유출
침투 도구: 리눅스 커널 기반 백도어 **BPFDOOR**

■ 사고가 드러낸 3가지 구조적 취약점

- ① 인증키(Ki) 평문 저장 → **핵심 자산보호 실패**
- ② BPFDOOR 잠복·스텔스 동작 → **패턴 기반 탐지의 사각지대**
- ③ 내부 확산·유출 경로 방치 → **경계 방어의 한계**

■ 시사점

경계 방어 중심의 단일 계층 보안만으로는 실제 침해 대응 불가
공격 → 탐지·차단 → 로그 분석으로 이어지는 다계층 진단 파이프라인 검증 필요

최종목표

■ 핵심 목표

가상 통신사 'FM 8+' 인프라를 대상으로 실제 공격을 재현하고,
탐지·차단·분석까지 관통하는 **END-TO-END 보안 진단 체계**
구축·검증

■ 세부 목표 (파이프라인)

RED TEAM: OWASP TOP 10 중 **5종 이상** 실제 익스플로잇
탐지·차단: 공격별 SNORT/SURICATA 시그니처 작성·탐지율 측정
로그 분석: ELK 기반 SIEM 대시보드로 공격 이벤트 시각화
통합 검증: 공격→탐지→로그 단일 시나리오 관통 및 타임라인 상관분석

02 프로젝트 팀 구성 및 역할

1

5인 팀 구성

팔로팔로미 · 8팀

2

Red · Blue · 관제 역할 분담

모의해킹 / 인프라 / 탐지·차단 / SIEM



프로젝트 팀 구성 및 역할



이름	역할	주요 업무 내용
김혜미	팀장 / 모의해킹·악성코드 분석 담당자	OWASP Top 10 취약점 선정, 악성코드 샘플 동적 분석으로 행위·IOC 도출, 보고서 작성.
조경익	서비스 인프라 담당자	웹서버·DB서버 등 VM 구성, MySQL/MariaDB 연동, 취약 계정/권한 의도적 설정, 발표
김유선	보안 인프라 담당자	pfSense(FW) → Suricata(IDS/IPS) → ModSecurity(WAF) 순으로 배치·검증.
이찬근	보안관제 담당자·악성코드 분석가	Suricata·WAF 룰 설정 후 탐지·차단 증빙, 악성코드 샘플 정적 분석으로 행위·IOC 도출, 발표 PPT 제작
정슬기	보안관제 담당자(SIEM)	ELK Stack로 FW/IDS·IPS/WAF 서버 로그를 중앙 수집·정규화, 대시보드로 공격 시도·차단 이력을 시각화.

03 프로젝트 수행절차 및 방법

1

STEP 1~2 · 기획 및 구축

위협 시나리오 정의 · VM 인프라 구축

2

STEP 3 · 모의 침투 진단

OWASP Top 10 · 악성코드 분석

3

STEP 4~5 · 탐지·차단 및 관제

Suricata/WAF 룰 · SIEM 시각화



프로젝트 수행절차 및 방법



STEP 1

기획 및 요구사항 정의

STEP 2

통신사 서비스 및
가상환경 구축

STEP 3

모의 침투 진단 및
취약점 검증

STEP 4

실시간 탐지·차단
파이프라인 구현

STEP 5

SIEM 중앙 로그 수집 및
관제 시각화

통신사 위협 시나리오 정의

다계층 방어 아키텍처 설계

기술 스택 확정
pfSense · Suricata · ELKVM 인프라 구축
(Kali / Web / DB)

취약 서비스 · 계정 의도적 설정

심층 방어 배치
FW → IDS/IPS → WAF웹 취약점 진단
OWASP Top 10

악성코드 정적 · 동적 분석

IOC 추출 및
공격 데이터 확보탐지 룰 커스텀
Suricata · ModSecurity자동 차단 대응
Shell Script
오탐/미탐 최소화 튜닝

로그 중앙 수집 · 정규화

통합 관제 대시보드

공격→탐지→차단
전 구간 검증

04 기술 스택 및 환경 구성

1

OS · 가상화

Ubuntu 24.04 · GNS3

2

공격 · DB 도구

Kali Linux · MariaDB

3

보안장비 · SIEM

pfSense · Suricata · ModSecurity · ELK



기술 스택 및 환경 구성



구분	기술 / 도구	버전 상세	용도
OS	Linux Server	ubuntu-24.04.4-live-server-amd64	웹 / DB / 보안장비 서버
가상화	GNS3	GNS3-2.2.57-all-in-one-regular	네트워크 구성도 제작 및 시뮬레이션
공격 도구	Kali Linux	2026.2 기반 rolling, 커널 7.0.12	모의해킹 공격 환경
DB	MySQL / MariaDB	MariaDB 10.11.14	취약 웹앱 연동 DB
보안 장비	pfSense / Suricata / ModSecurity	2.7.2-RELEASE / 7.0.8_1 / ModSecurity 2.9.7	방화벽, IDS·IPS, WAF
SIEM	ELK Stack (Elasticsearch, Logstash, Kibana)	Elastic Stack 8.19.19 (Elasticsearch 8.19.19 / Logstash 8.19.19 / Kibana 8.19.19)	실시간 중앙 수집 및 정규화 로그 대시보드

05

비즈니스 흐름도 / FM 8+ 인프라 구성도

1

비즈니스 흐름도

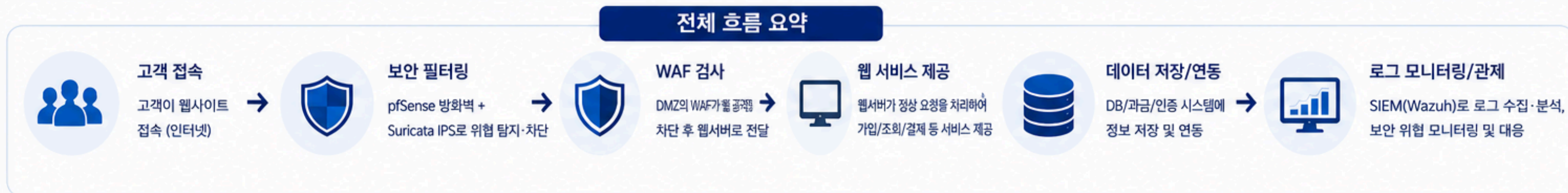
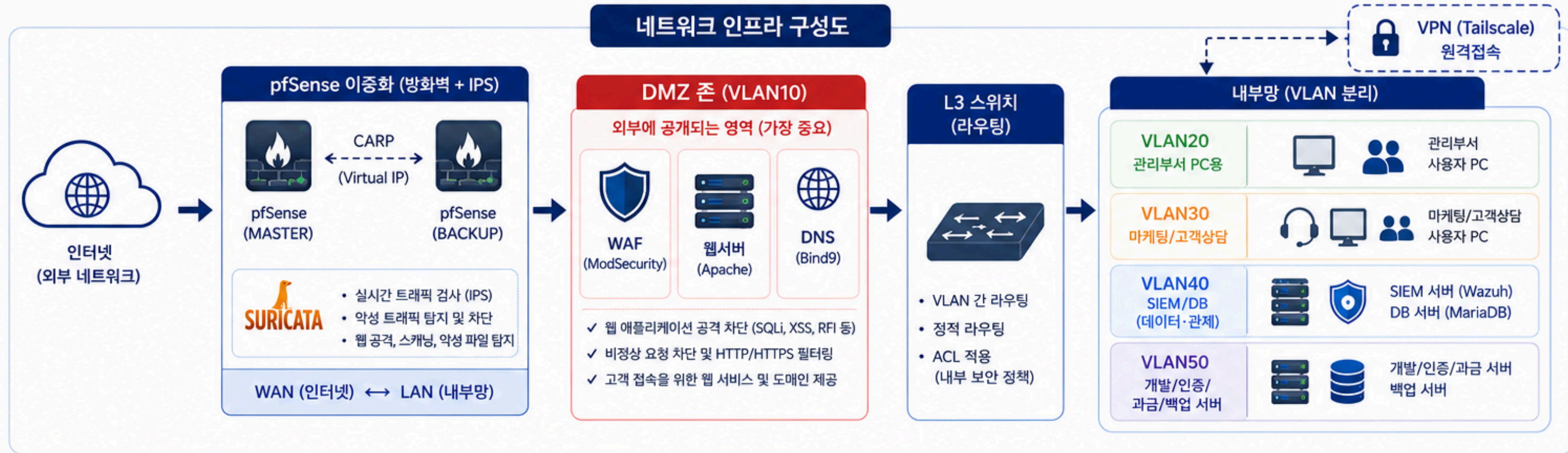
고객 접속 → 보안검사 → 서비스 제공

2

FM 8+ 인프라 구성도

pfSense 이중화 · DMZ · VLAN 분리 · VPN

비즈니스 흐름도 / FM 8+ 인프라 구성도



06 네트워크 환경 구성도

1

내부망 · VLAN 분리

VLAN 20~50 · 부서·서버 세그먼트

2

DMZ · 외부망

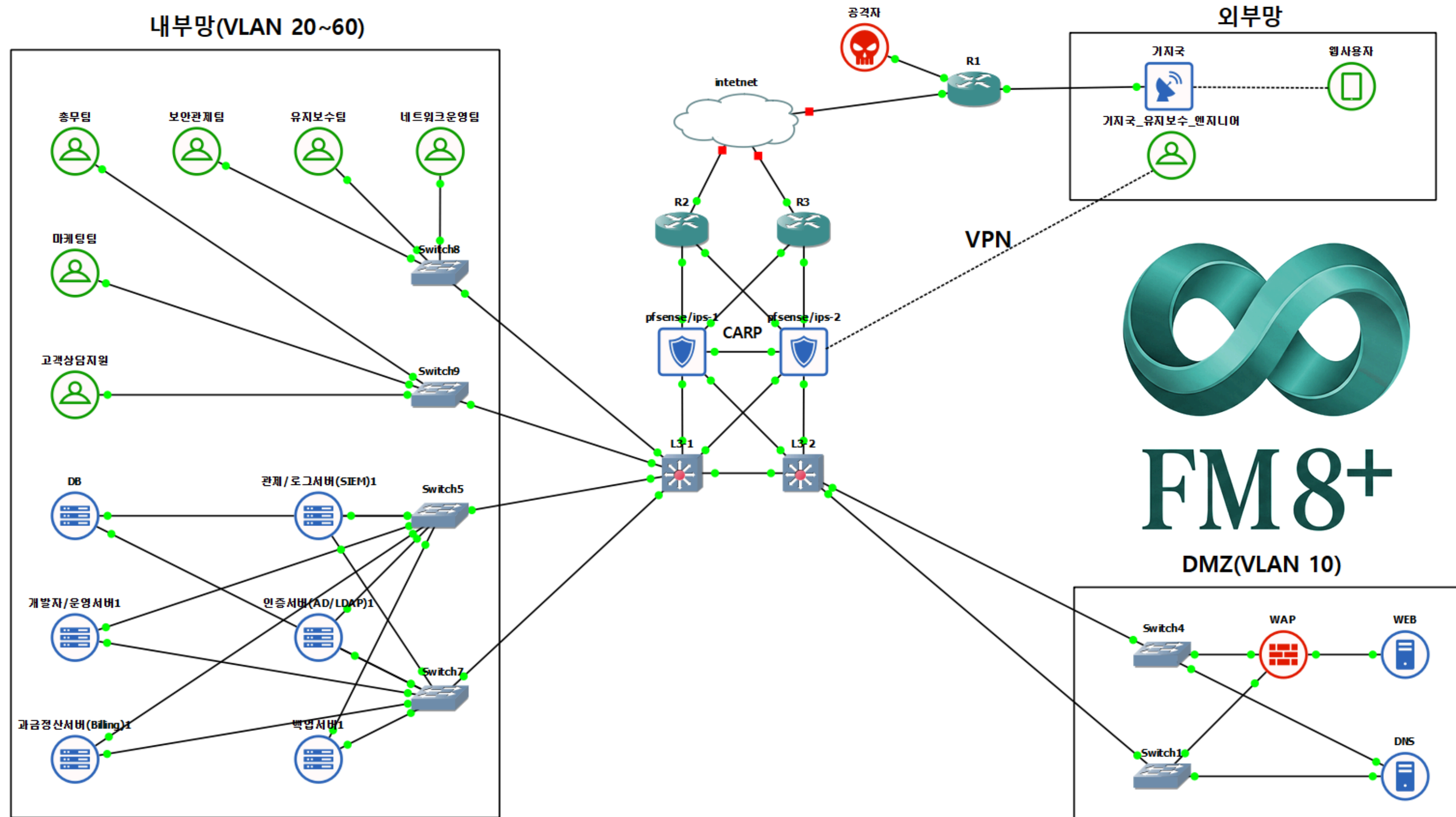
WEB·DNS 공개 영역 · 기지국·공격자

3

VPN 원격 접속

Tailscale 기반 내부망 접근

네트워크 환경 구성도



보안 인프라 구축

1 DB 구축
fm8plus DB · 13개 테이블 · 최소 권한 원칙

2 WAF (ModSecurity)
OWASP CRS · SQLi / XSS / 업로드 차단

3 pfSense 이중화 (HA / CARP)
VIP 승계 · 단일 장애점(SPOF) 제거

4 포트 포워딩
WAN VIP → WAF → WEB Server



메인 페이지



요금제 단말기 인터넷/TV 혜택 고객지원

기업고객 로그인 검색 고객센터

FM 8+ EXCLUSIVE

더 빠른 연결, 더 넓은 세상으로

FM 8+와 함께라면 어디서든 끊김 없이. 신규 가입 고객 대상 특별 혜택을
지금 확인하세요.

요금제 보러가기

혜택 둘러보기



1,240만

누적 가입자

99.98%

전국 커버리지

전국 8,200+

대리점/서비스센터

1위

통신 고객만족도(가상 지표)



요금제 조회



단말기 구매



인터넷/TV 결합



요금 납부



이벤트/혜택



관리자 페이지



주의 요함

https://fm8plus.com/admin/



Admin Console

관리자 로그인

FM 8+ NOC / Admin Console에 접속합니다.

아이디

비밀번호

로그인

이 페이지는 관리자 전용입니다 · FM 8+ Enterprise



관리자 페이지



Admin Console

NOC

Admin > Dashboard

Q 회원, 문의, 요금제 검색...

14:01:07



관리자
Administrator



Dashboard



회원관리



서비스관리



요금관리



문의관리



공지사항



통계



시스템



관리자

Dashboard

FM 8+ 서비스 운영 현황을 한눈에 확인하세요.

총 가입자



5

누적

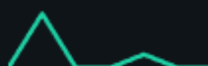


오늘 가입



0

0%



오늘 문의



0

0%

매출 (납부완료)



0원

누적

장애 건수



2

2건



활성 서비스



1

정상

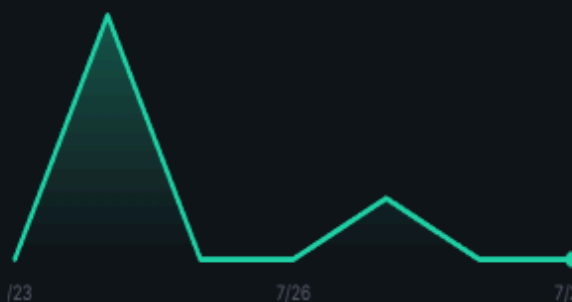
실시간 방문자

7일



가입 추이

7일



문의 추이

7일



실시간 알림

시스템 정상 운영 중
실시간

새로운 알림이 없습니다

최근 문의

전체보기

문의 내역이 없습니다

최근 가입자

전체보기

1	1234 @1234	2일 전
a	admin @test	5일 전
박	박민수 @member01	5일 전

최근 공지

전체보기

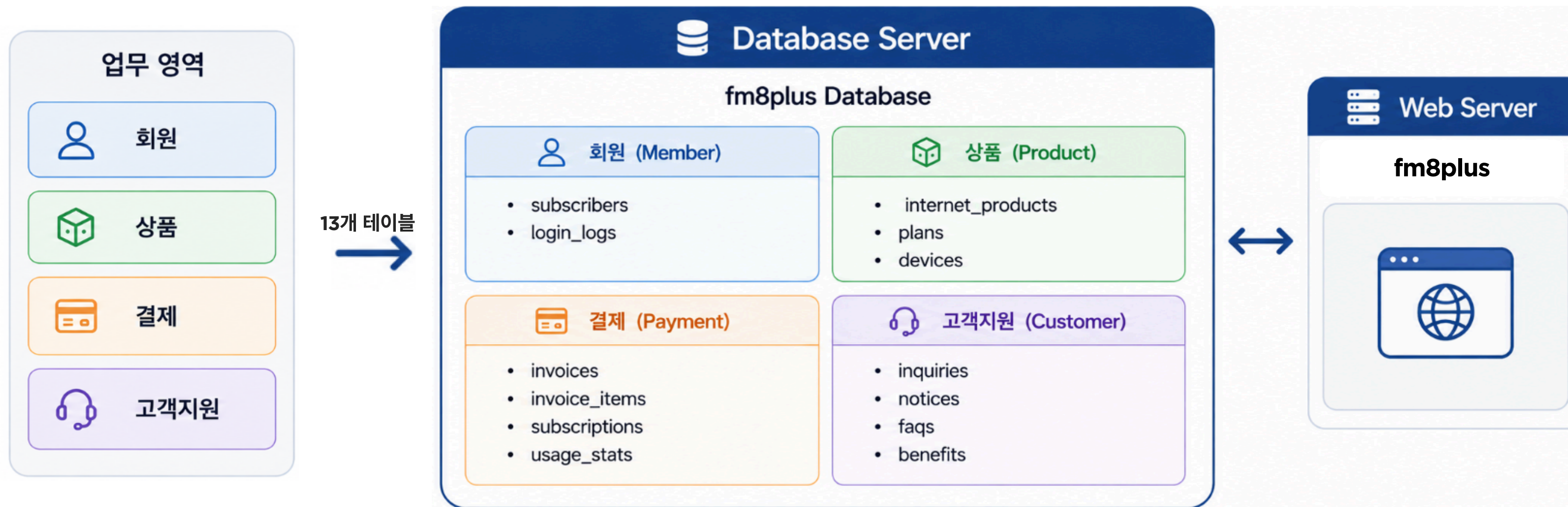
📢	개인정보 처리방침 개정 안내 10일 전
📢	신규 요금제 FM 프리미엄 출시 7일 전
📢	7월 정기 시스템 점검 안내 5일 전

최근 로그인

관	관리자 @admin	방금 전
관	관리자 @admin	3시간 전
관	관리자 @admin	4시간 전
관	관리자 @admin	4시간 전



DB 구축



※ 4개 업무 영역을 13개 테이블로 분리 설계

보안 설계

- ✓ Web Server만 접근 허용
- ✓ 전용 DB 계정(fm8plus) 사용
- ✓ 접속 IP 제한
- ✓ 최소 권한 원칙 적용

설계 의도

- ✓ 취약점 실습 환경 구현
- ✓ DB는 최소 권한 원칙 적용
- ✓ 실제 운영 환경을 고려한 설계



WAF 구축 (ModSecurity)



구축 환경

사용 기술

Apache
ModSecurity
OWASP CRS
Paranoia Level 2

구축 위치

DMZ (VLAN10)
웹 서버 앞단 배치
Reverse Proxy 구성

HTTPS

HTTPS(443)
SSL 인증서 적용
HTTPS 암호화 통신

검증 방법

SQL Injection
Stored XSS
WebShell Upload
IDOR

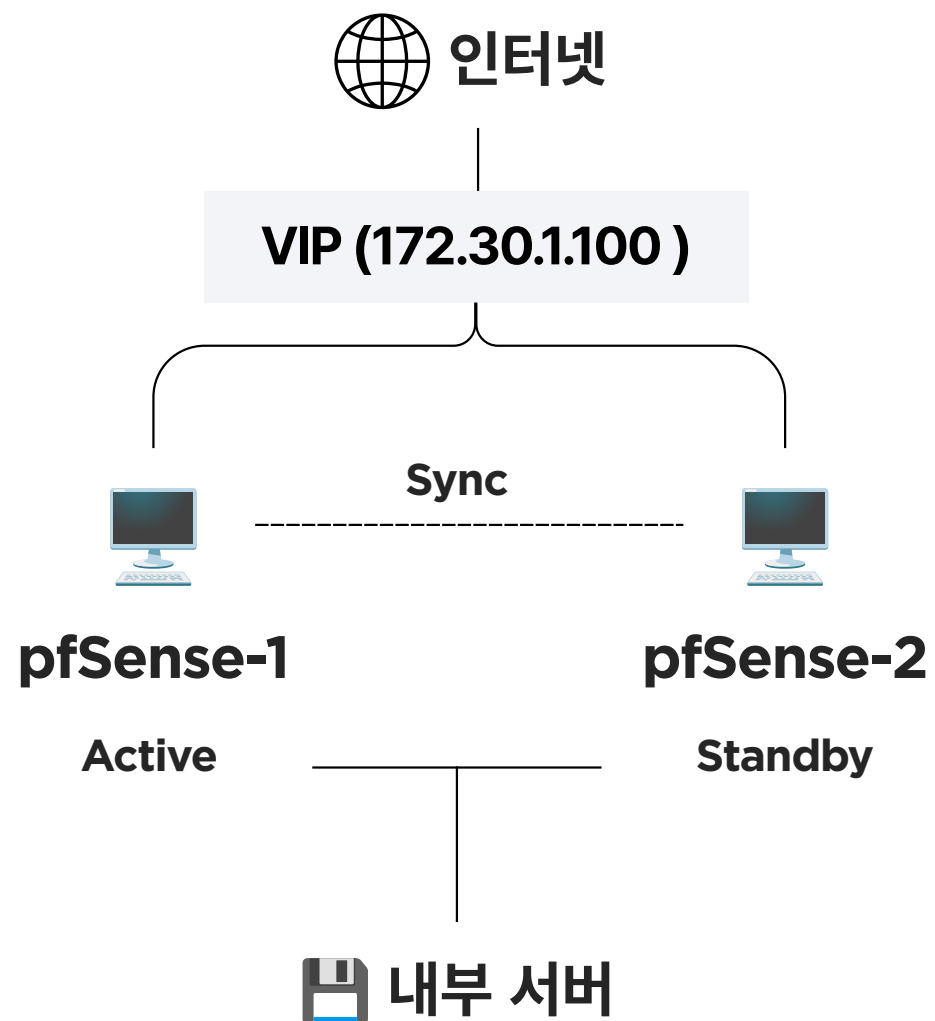
검증 결과

공격	결과	비고
SQL Injection	✅ 차단	HTTP 403 반환
Stored XSS	✅ 차단	OWASP CRS Rule 적용
WebShellUpload	✅ 차단	파일 업로드 차단
IDOR	❌ 미탐지	권한 검증 로직 필요

※ WAF는 SQL Injection, Stored XSS, WebShell Upload 공격을 차단하였으며, IDOR는 애플리케이션의 권한 검증이 필요함을 확인하였다.

pfSense 이중화(HA/CARP) 구축

구축 목적



구축 환경

가상 IP (VIP)

WAN : 172.30.1.100
CARP 기반
외부에서 동일 IP로 접속

동기화 방식

CARP 프로토콜
XMLRPC Sync
설정 자동 동기화

Sync 전용 네트워크

em2 인터페이스
pfSense-1 : 10.10.10.1
pfSense-2 : 10.10.10.2

검증 방법

Active 장비 강제 종료
Standby 승계 확인
Virtual IP 및 서비스 확인

구축 효과

단일 장애 지점 (SPOF) 제거

방화벽 장애 시 전체 서비스 중단 방지

자동 Failover

CARP 기반 자동 승계로 중단 최소화

서비스 연속성 확보

네트워크 및 보안 서비스 24/7 유지

고가용성(HA) 구현

이중화 구성으로 안정성 및 신뢰성 향상



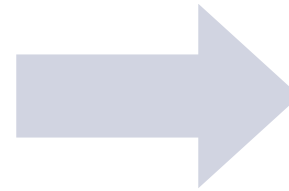
pfSense 이중화(HA/CARP) 구축



CARP Status			
Interface and VHID	Virtual IP Address	Description	Status
WAN@1	172.30.1.100/24	WAN	▶ MASTER
DMZ@10	192.168.10.3/26	DMZ	▶ MASTER
ADMIN@20	192.168.20.3/26	ADMIN	▶ MASTER
MARKETING@30	192.168.30.3/26	MARKETING	▶ MASTER
SIEM_DB@40	192.168.40.3/26	SIEM_DB	▶ MASTER
DEV_INFRA@50	192.168.50.3/26	DEV_INFRA	▶ MASTER

CARP Status			
Interface and VHID	Virtual IP Address	Description	Status
WAN@1	172.30.1.100/24	WAN	⏸ BACKUP
DMZ@10	192.168.10.3/26	DMZ	⏸ BACKUP
ADMIN@20	192.168.20.3/26	ADMIN	⏸ BACKUP
MARKETING@30	192.168.30.3/26	MARKETING	⏸ BACKUP
SIEM_DB@40	192.168.40.3/26	SIEM_DB	⏸ BACKUP
DEV_INFRA@50	192.168.50.3/26	DEV_INFRA	⏸ BACKUP

pfSense 1에 장애 발생



pfSense 2 마스터 상태

흠... 이 페이지에 연결할 수 없습니다.

172.30.1.33 응답하는 데 시간이 너무 오래 걸렸습니다.

다음을 시도해 보세요.

- 연결을 확인하는 중
- [프록시 및 방화벽 점검 중](#)

ERR_CONNECTION_TIMED_OUT

새로 고침

CARP Status			
Interface and VHID	Virtual IP Address	Description	Status
WAN@1	172.30.1.100/24	WAN	▶ MASTER
DMZ@10	192.168.10.3/26	DMZ	▶ MASTER
ADMIN@20	192.168.20.3/26	ADMIN	▶ MASTER
MARKETING@30	192.168.30.3/26	MARKETING	▶ MASTER
SIEM_DB@40	192.168.40.3/26	SIEM_DB	▶ MASTER
DEV_INFRA@50	192.168.50.3/26	DEV_INFRA	▶ MASTER

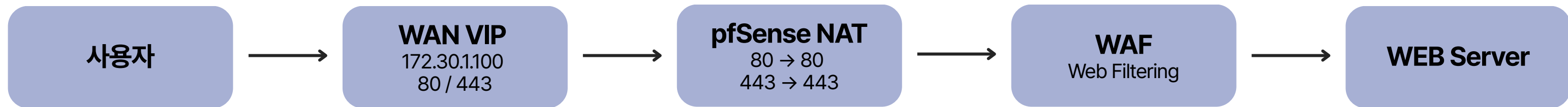
State Synchronization Status

State Creator Host IDs:

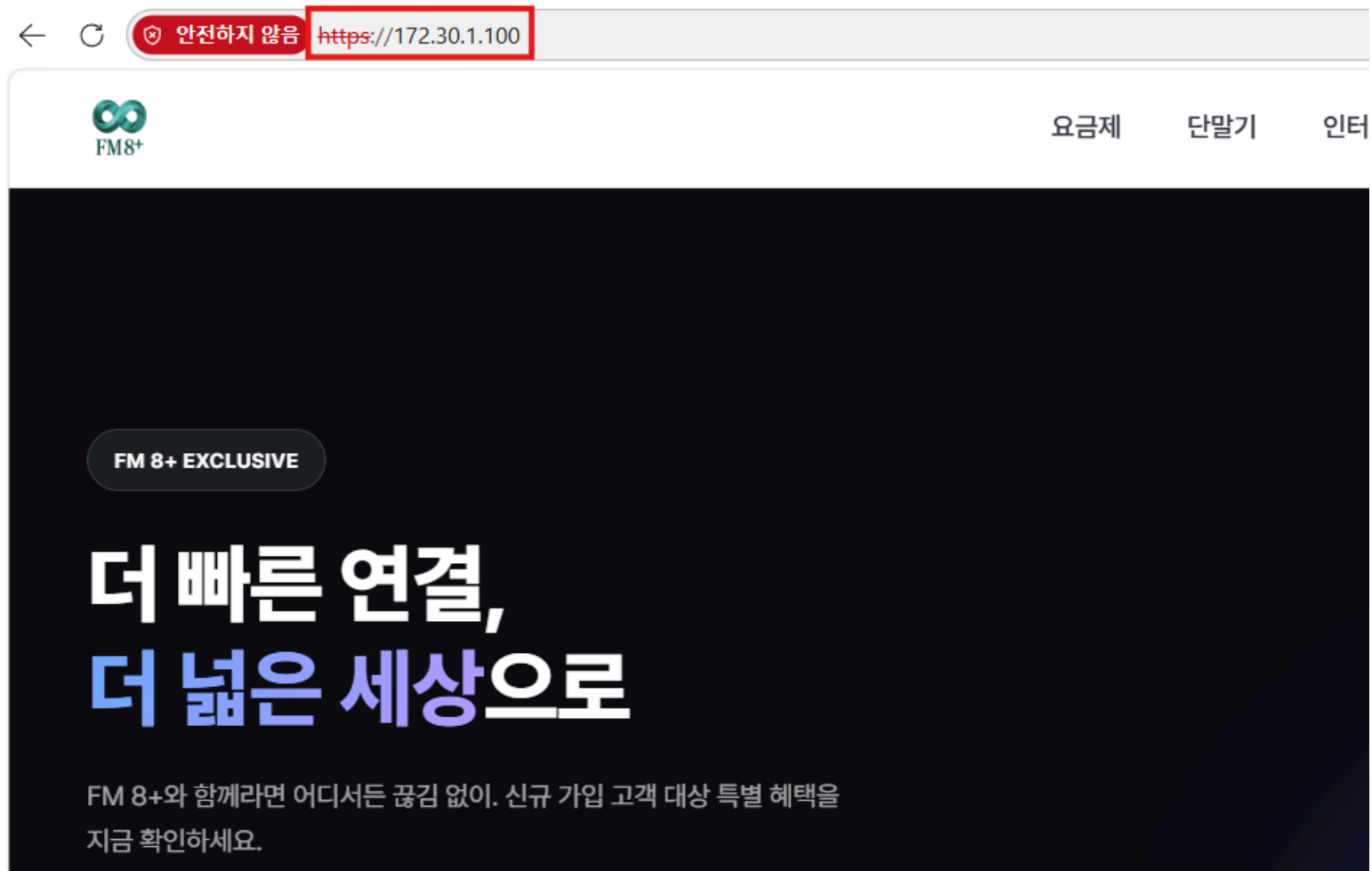
- 352113b1
- 3873c8cc (This node)

포트 포워딩

포트 포워딩 흐름



※ 모든 웹 요청은 WAF를 거친 후 WEB Server로 전달



Rules										
	Interface	Protocol	Source Address	Source Ports	Dest. Address	Dest. Ports	NAT IP	NAT Ports	Description	Actions
☐	WAN	TCP	*	*	172.30.1.100	80 (HTTP)	192.168.10.11	80 (HTTP)	WAN VIP → WAF 80	
☐	WAN	TCP	*	*	172.30.1.100	443 (HTTPS)	192.168.10.11	443 (HTTPS)	WAN VIP → WAF 443	

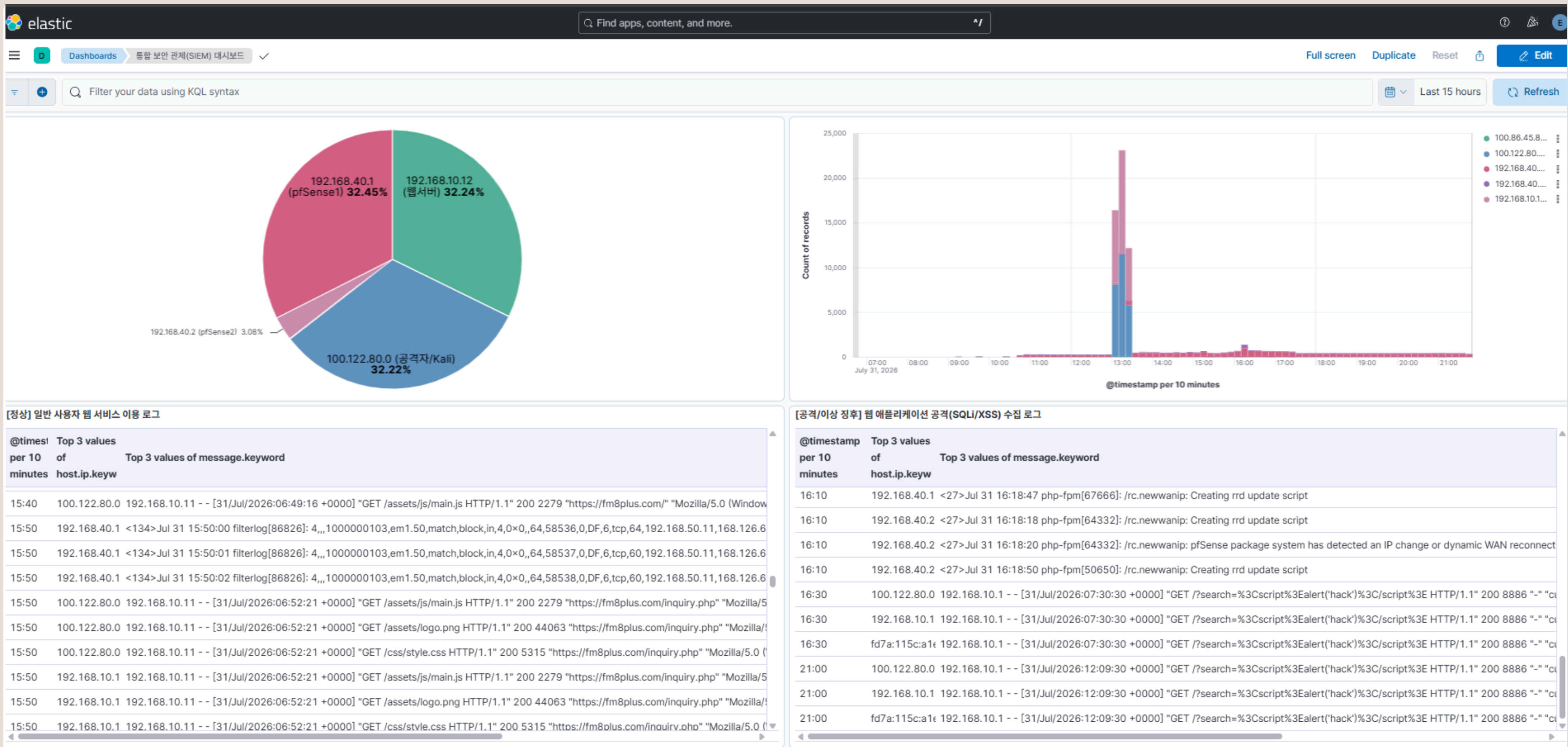
NAT Rule인 HTTP(80), HTTPS(443)를 통해 WAF로 전달

포트 포워딩 결과

- ✓ WAN VIP를 통한 서비스 제공
- ✓ 내부 WEB Server IP 비노출
- ✓ 모든 HTTP/HTTPS 요청은 WAF를 거쳐 전달

※ 외부 사용자는 실제 웹 서버가 아닌 WAN VIP(172.30.1.100)로 접속

SIEM 대시보드 구축



07 악성코드 분석 결과

1 선정 배경
SKT 침해사고 · Linux 코어망 표적

2 정적 분석
VirusTotal · DiE · Ghidra

3 동적 분석
strace · Wireshark · Scapy

4 결론 및 대응 방안
Raw Socket 감시 · IDS 룰 · EDR

※ 자세한 내용은 악성코드 분석 보고서 확인 부탁드립니다.



악성코드 분석 결과 | 선정 배경



선정 이유

실제 통신사 침해사고 조사



BPFDDoor 사용 사례 확인



BPFDDoor를 분석 대상으로 선정



통신사 환경 기반 보안 프로젝트 기획

프로젝트 환경 적합성

- ✓ Linux 기반 코어망 표적
- ✓ 방화벽 및 ACL 등 경계 통제 우회
- ✓ 장기간 잠복 가능

실제 국내 침해사고에서 사용

- ✓ 2025년 SKT 침해사고
- ✓ BPFDDoor 계열 악성코드 확인
- ✓ 장기간 잠복 및 탐지 실패

분석 가치

- ✓ 탐지 우회 구조 분석
- ✓ 탐지 및 대응 방안 도출

※ 자세한 내용은 악성코드 분석 보고서 확인 부탁드립니다.



악성코드 분석 결과 | BPFDoor 동작 개요



STEP 1

RAW PACKET SOCKET 생성

AF_Packet, sock_raw

STEP 2

네트워크 인터페이스 조회

ioctl, SIOCGIFINDEX

STEP 3

인터페이스 바인딩

bind

STEP 4

패킷 지속 수신
Recvfrom, 무한 루프

STEP 5

Magic Packet 판별
is_magic_packet /
memcmp

STEP 6

리버스셸 실행
spawn_reverse_shell
→ /bin/sh



악성코드 분석 결과 | 정적 분석



정적 분석

사용 도구

VirusTotal

Detect It Easy(DiE)

Ghidra

file / strings / readelf

VirusTotal

- 84개 보안 엔진 중 5개 엔진에서 악성으로 탐지
- Code Insights를 통해 BPFDoor 계열과 유사한 동작 확인

Detect It Easy(DiE)

- Linux ELF64 실행 파일
- AMD64, PIE, Dynamic Linking 구조 확인

Ghidra

- Raw Packet Socket 생성 과정 확인
- main(), is_magic_packet(), spawn_reverse_shell() 함수 분석
- Magic Packet 탐지 후 Reverse Shell 실행 구조 확인

Linux 분석 도구

- file : ELF64 / PIE / not stripped 확인
- strings : "MAGIC", "/bin/sh" 문자열 확인
- readelf : Dynamic Section 및 심볼 정보 확인

핵심 분석 결과

- ✓ ELF64 실행 파일
- ✓ Raw Packet Socket 기반
- ✓ Magic Packet 탐지
- ✓ Reverse Shell 실행

※ 자세한 내용은 악성코드 분석 보고서 확인 부탁드립니다.



악성코드 분석 결과 | 동적 분석



동적 분석

사용 도구

SS

WireShark

strace

Scapy

SS

- 일반 TCP Listening Port 미생성
- Raw Packet Socket(p_raw) 생성 확인
- bpfdoor_demo 실행 확인

WireShark

- TCP/31337 패킷 수신 확인
- "MAGIC-DEMO" Payload 확인
- Reverse Shell 통신 확인

strace

- socket(AF_PACKET, SOCK_RAW)
- ioctl(SIOCGIFINDEX)
- bind(), recvfrom()
- 주요 시스템 콜 호출 확인

Scapy

- Magic Packet 생성
- TCP/31337 패킷 전송
- BPFDoor 동작 트리거

핵심 분석 결과

✓ Raw Packet Socket 생성 확인 ✓ Magic Packet 수신 확인 ✓ Reverse Shell 실행 확인 ✓ 정적 분석 결과와 일치

※ 자세한 내용은 악성코드 분석 보고서 확인 부탁드립니다.



악성코드 분석 결과 | 결론 및 대응 방안



최종 결론

정적 분석과 동적 분석을 통해 BPFDoor PoC의 핵심 동작인

- ✓ Raw Packet Socket 기반 패킷 감시
- ✓ Magic Packet Trigger
- ✓ Reverse Shell 실행

구조를 성공적으로 검증하고,이를 기반으로 탐지 및 대응 방안을 제시하였다.

대응 방안

- ✓ Raw Socket 생성 모니터링
- ✓ IDS/IPS 탐지 Rule 적용
- ✓ EDR / Sysmon 로그 분석
- ✓ 비인가 Root 프로세스 점검

※ 자세한 내용은 악성코드 분석 보고서 확인 부탁드립니다.

08 모의 해킹 결과

1

취약점 5종 진단

SQL Injection · Session Fixation · XSS · IDOR · File Upload

2

취약점 결합 공격 시나리오

XSS × Session Fixation → 관리자 세션 탈취

3

종합 평가 및 대응 우선순위

공통 근본원인 · 조치 우선순위

※ 자세한 내용은 모의 해킹 보고서 확인 부탁드립니다.



모의 해킹 결과 | 진단 개요 & 결과 요약



진단 대상 · 환경

대상 서비스 FM 8+ (통신사 테마 웹 애플리케이션)
접속 주소 http://fm8plus.com (내부 사설망)
서버 환경 Ubuntu / Apache 2.4.58 / PHP / MariaDB
공격 위치 Kali Linux (VirtualBox, 팀 사설망)
사용 도구 Burp Suite · sqlmap · nc · curl

진단 원칙 팀이 자체 구축한 격리 가상환경에서만 수행 · 공격 재현 전 대상 VM 스냅샷 확보로 원복 상태 유지

5

취약점 실증

3

Critical

2

High

진단 범위 — OWASP TOP 10 기반 5개 항목

No	대상 취약점	심각도	OWASP
1	SQL Injection	Critical	A05 Injection
2	Session Fixation	High	A07 Auth Failures
3	Stored XSS	Critical	A05 Injection
4	IDOR	High	A01 Access Control
5	File Upload	Critical	A02 Misconfig

→ 5건 전부 실제 익스플로잇 실증 · 3건은 RCE 또는 전체 회원정보 유출로 직결되는 치명적 수준

※ 자세한 내용은 모의 해킹 보고서 확인 부탁드립니다.



모의 해킹 결과 | ① SQL Injection — 회원 로그인

SQL Injection — 회원 로그인 인증 우회

Critical

A05

<http://fm8plus.com/login-handler.php>

공격 재현 흐름

- ① 인증 우회 userid에 SQL 구문 주입 → 로그인 성공
- ② 자동화 sqlmap으로 subscribers 테이블 전체 덤프
- ③ 계정 탈취 덤프한 admin / admin1234로 관리자 로그인 성공

```
{"userid":"admin' -- ", ...} → 인증 로직 뒷부분 주석 처리, 우회 성공  
$ sqlmap -r login.txt --dump -D fm8plus  
Table: subscribers [5 entries] 전체 덤프
```

위험도

인증 우회 → 전체 회원 개인정보(이름·연락처·평문 비밀번호) 유출 → 관리자 계정 탈취로 서비스 전체 통제권 상실

근본 원인 & 대응

사용자 입력을 SQL 쿼리 문자열에 직접 결합(concatenation)해, 파서가 입력을 '데이터'와 '쿼리 구조' 중 무엇으로도 해석. 게다가 인증을 password_plain(평문 컬럼)과 직접 비교 bcrypt 해시 컬럼이 있어도 무력화 상태.

```
// 취약: 문자열 결합 $sql="...WHERE username='$username'";  
// 패치: Prepared Statement + 해시검증 $stmt->prepare('...WHERE  
username=?');if(password_verify($pw,$row['password_hash']))
```

대응

모든 쿼리 Prepared Statement 적용 · 평문 비밀번호 컬럼 제거 · DB 계정 최소권한 · WAF(ModSecurity) SQLi 시그니처 1차 방어선



모의 해킹 결과 | ② Session Fixation · ③ Stored XSS



Session Fixation

login-handler.php · 세션 처리

High

A07

공격

로그아웃 → 재로그인 → 로그인 후까지 PHPSESSID 값이 전 구간 동일.
로그인 성공 응답에 Set-Cookie 없음.

원인

로그인 성공 시 session_regenerate_id(true) 호출 누락 →
비로그인 세션ID가 그대로 '인증된 세션'으로 승격.

방어

로그인 시점 세션 재발급 · 로그아웃 시
session_destroy() · 쿠키 HttpOnly·Secure·SameSite 적용.

Stored XSS

inquiry.php · 1:1 문의 게시판

Critical

A05

공격

문의 content에 <script>alert(document.cookie)</script> 저장
→ 상세 열람 시 필터링 없이 실행, 세션 쿠키 노출.

원인

출력 단계에서 HTML 인코딩 미적용. 입력을 HTML 문서에 그대로
삽입해 브라우저가 실행 가능 코드로 해석.

방어

출력 시 HTMLSPECIALCHARS() 필수 · CSP 헤더로
인라인 스크립트 제한 · 쿠키 HTTPONLY로 탈취 원천 차단.

SQLi가 '입력 단계'의 데이터/코드 미분리 문제라면, XSS는 '출력 단계'에서 동일 문제가 발생하는 것

두 취약점은 login-handler.php 한 파일에서 함께 기인 — **session_regenerate_id() 한 줄의 부재.**
XSS로 탈취한 세션이 재발급되지 않아 그대로 유효하게 유지되는 점이 다음 장 결합 공격의 핵심 연결고리.

※ 자세한 내용은 모의 해킹 보고서 확인 부탁드립니다.



모의 해킹 결과 | ④ IDOR · ⑤ Unrestricted File Upload



IDOR

mypage.php · 요금/사용량 조회

High

A01

공격

로그인 상태에서 mypage.php?member_id 값을 1·4로 조작
→ 동일 세션으로 타 회원 성명·연락처·요금제·사용량 열람.

원인

인증(로그인)은 검증하나 인가(리소스 소유자 확인) 부재.
Prepared Statement로도 못 막는 별개 취약점.

방어

요청 리소스 소유자와 세션 user_id 일치 여부를 매 요청 검증 ·
식별자 UUID 대체 · 이상 요청 패턴 SIEM 연동.

핵심 시사점

IDOR은 SQLi 대응(Prepared Statement)만으로 못 막는다.
쿼리 구조가 안전해도 파라미터 '출처(사용자 입력 vs 세션)'를 검증하지
않으면 인가 취약점은 별도로 남는다.

File Upload

upload.php · 본인인증 서류 첨부

Critical

A02

공격

shell.php를 확장자 변조 없이 업로드 →
/uploads/shell.php?cmd=id 로 리눅스 명령어·웹루트 소스 열람.

원인

확장자·MIME·매직바이트 서버측 검증 전무 +
업로드 디렉토리 PHP 실행 허용(서버 기본값)이 결합.

방어

확장자+MIME 화이트리스트 이중검증 · 랜덤 파일명 저장 ·
업로드 디렉토리 스크립트 실행 차단(APACHE).

File Upload = 최상위 위험

웹셸(RCE)로 확보한 서버 접근이 나머지 취약점의 실제 소스코드를
직접 확인하는 발판(foothold)이 되어, 근본 원인 분석의 물리적 근거를
제공했다.



모의 해킹 결과 | 취약점 결합 공격 시나리오



Stored XSS × Session Fixation → 인증 절차 없는 관리자 세션 완전 탈취

STORED XSS



세션 탈취



Session Fixation



권한 탈취

1:1 문의 게시판에 세션 쿠키를
외부로 전송하는 스크립트 등록

관리자가 문의글 열람하는 순간
스크립트 실행 → 관리자
PHPSESSID 전송

서버가 세션을 재발급하지 않아
탈취한 PHPSESSID가 계속 유효

curl로 PHPSESSID 재사용 →
로그인 절차 없이 관리자 권한 접근

```
$ curl -b \ "PHPSESSID=<탈취값>" \
fm8plus.com/mypage.php
→ 관리자 정보 그대로 노출 → ID/PW 입력 없이 세션 재사용 성공
```

시사점

개별 취약점(XSS·Session Fixation)이 결합되면 위험도가
산술적이 아니라 급격히 상승한다.

HttpOnly 쿠키 속성 하나만 적용됐어도
document.cookie 접근이 차단돼 전체 체인이 성립하지 않았을 것.

※ 자세한 내용은 모의 해킹 보고서 확인 부탁드립니다.



모의 해킹 결과 | 종합 평가



5개 항목 전부 실제 익스플로잇 가능, 3건은 RCE 또는 전체 회원정보 유출로 직결.

다수 취약점이 **입력값 검증 부재** + **출력·저장 단계의 신뢰 과잉**이라는 공통 근본 원인을 공유 → **시큐어 코딩 가이드라인 부재**가 구조적 원인.

우선순위	대상 취약점	조치	기대 효과
1순위	File Upload · SQLi	입력 검증 · Prepared Statement	RCE 및 DB 전체 탈취 경로 원천 차단
2순위	XSS · Session Fixation	출력 인코딩 · HttpOnly · 세션 재발급	세션 하이재킹 공격 체인 차단
3순위	IDOR	리소스 소유자 서버측 검증 추가	개인정보 대량 유출 방지
4순위	공통	평문 비밀번호 제거 · WAF/IDS 룰셋	2차 피해 최소화 · 조기 탐지 체계

※ 자세한 내용은 모의 해킹 보고서 확인 부탁드립니다.

09 기업 정보보호 점검 결과

1

탐지 · 차단 파이프라인

공격 → 탐지룰 → 액션 매핑 (drop 13 · alert 2)

2

IDS · IPS 탐지 결과

WAN 룰 10개 · LAN 룰 5개 커스텀 시그니처

3

WAF 탐지 · 차단 결과

SQLi · XSS · 웹셸 업로드 403 차단

4

SIEM 통합 로그 분석

정상 · 공격 트래픽 비교 및 이상징후 탐지

※ 자세한 내용은 기업 정보 보호 점검 보고서 확인 부탁드립니다.



기업 정보보호 점검 결과 | 공격 → 탐지률 → 단일 파이프라인



Red Team의 모든 공격 단계를 Snort/Suricata 룰로 매핑하고, 위험도에 따라 자동 차단(drop) 또는 탐지 관찰(alert)로 분기합니다.



① 공격 (Red Team)

- 웹 - SQLi·XSS·IDOR·업로드
- 네트워크 - 스캔·리버스셸
- BPFDoor 매직패킷·SSH 무차별



② 탐지률 (IPS)

- WAN 룰 10개
- LAN 룰 5개
- content / threshold / flow 매칭



③ 액션 분기

- drop → 즉시 차단 (13개)
- alert → 로그·SIEM 관찰 (2개)
- ELK 상관분석 연계

결과 요약

15

Custom Rules
(WAN 10 + LAN 5)

13

자동 차단 (drop)

2

탐지 관찰 (alert)

※ 자세한 내용은 기업 정보 보호 점검 보고서 확인 부탁드립니다.



기업 정보보호 점검 결과 | IDS·IPS (WAN)



Date	Action	Pri	Proto	Class	Src	SPort	Dst	DPort	GID:SID	Description
08/03/2026 00:41:18		1	TCP	Web Application Attack	172.30.1.6 	62861	172.30.1.100 	80	1:1000001 	FM8+ SQL Injection UNION SELECT
08/03/2026 00:41:16		1	TCP	Web Application Attack	172.30.1.6 	62860	172.30.1.100 	80	1:1000002 	FM8+ XSS Script Injection
08/03/2026 00:41:14		3	TCP	Not Assigned	172.30.1.6 	62858	172.30.1.100 	80	1:1000003 	FM8+ Repeated Login POST Requests
08/03/2026 00:41:12		1	TCP	Web Application Attack	172.30.1.6 	62849	172.30.1.100 	80	1:1000004 	FM8+ Suspicious PHP File Upload
08/03/2026 00:41:10		3	TCP	Not Assigned	172.30.1.6 	62848	172.30.1.100 	80	1:1000005 	FM8+ Admin Inquiry Page Access
08/03/2026 00:41:08		3	TCP	Not Assigned	172.30.1.6 	62847	172.30.1.100 	80	1:1000006 	FM8+ Member ID Parameter Access
08/03/2026 00:41:04		3	TCP	Not Assigned	172.30.1.6 	62844	172.30.1.100 	80	1:1000007 	FM8+ Directory Traversal Attempt
08/03/2026 00:41:02		3	TCP	Not Assigned	172.30.1.6 	62843	172.30.1.100 	80	1:1000008 	FM8+ SQLMap Scanner Detected
08/03/2026 00:41:00		3	TCP	Not Assigned	172.30.1.6 	62842	172.30.1.100 	80	1:1000009 	FM8+ Sensitive File Access
08/03/2026 00:40:57		3	TCP	Not Assigned	172.30.1.6 	62841	172.30.1.100 	80	1:1000010 	FM8+ Command Injection Attempt

탐지된 공격 ↔ 룰 매핑

1000001	SQL Injection	drop
1000002	Stored XSS (<script	drop
1000003	로그인 반복 시도 (Brute Force)	drop
1000004	PHP 파일 업로드	drop
1000005	관리자 문의 페이지 접근	alert
1000006	member_id (IDOR)	alert
1000007	Directory Traversal	drop
1000008	sqlmap 스캐너	drop
1000009	민감 파일 접근 (.env)	drop
1000010	Command Injection	drop

drop 자동 차단 alert 탐지·관찰

왜 1000005·1000006만 alert 인가?

관리자 페이지 접근과 IDOR(member_id)은 정상 요청과 페이로드가 구조적으로 동일하여 시그니처로 차단이 불가능합니다. 차단 시 정상 업무가 마비되므로 로그만 남기고, "한 세션이 여러 member_id를 순회"하는 패턴은 ELK 상관분석으로 판별합니다.

※ 자세한 내용은 기업 정보 보호 점검 보고서 확인 부탁드립니다.



기업 정보보호 점검 결과 | IDS·IPS (LAN)



Date	Action	Pri	Proto	Class	Src	SPort	Dst	DPort	GID:SID	Description
08/03/2026 11:04:41		1	TCP	A Network Trojan was detected	192.168.10.12 	48302	172.30.1.6 	4444	1:1000101 	FM8+ Reverse Shell Outbound 4444
08/03/2026 11:04:23		1	TCP	A Network Trojan was detected	192.168.30.11 	41414	192.168.10.12 	31337	1:1000102 	FM8+ BPFDoor Magic Trigger
08/03/2026 11:04:23		1	TCP	A Network Trojan was detected	192.168.30.11 	41414	192.168.10.12 	31337	1:1000102 	FM8+ BPFDoor Magic Trigger
08/03/2026 11:02:01		2	TCP	Attempted Information Leak	192.168.10.12 	36190	192.168.50.11 	21	1:1000103 	FM8+ Internal Port Scan
08/03/2026 11:01:55		3	TCP	Not Assigned	192.168.30.11 	46468	192.168.10.12 	22	1:1000104 	LAN - Internal SSH Brute Force Attempt Detected
08/03/2026 11:01:55		3	TCP	Not Assigned	192.168.30.11 	46450	192.168.10.12 	22	1:1000104 	LAN - Internal SSH Brute Force Attempt Detected
08/03/2026 11:01:41		3	TCP	Not Assigned	192.168.30.11 	58340	172.30.1.6 	5938	1:1000105 	LAN - Unauthorized Remote Control or Tunneling Traffic

탐지된 공격 ↔ 룰 매핑

1000101	Reverse Shell (4444)	drop
1000102	BPFDoor	drop
1000103	Port Scan	drop
1000104	SSH Brute Force	drop
1000105	원격제어	drop

drop 자동 차단

alert 탐지·관찰

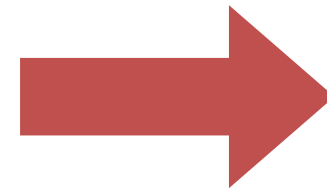
※ 자세한 내용은 기업 정보 보호 점검 보고서 확인 부탁드립니다.

기업 정보보호 점검 결과 | WAF

SQL Injection
탐지 원리

탐지대상

SQLi — '--, '#, union select, or 1=1 패턴



union select뿐만 아니라 admin' -- 같은 로그인 우회 패턴까지 넓힘

XSS 탐지 원리

탐지대상

XSS — <script

WebShell
탐지 원리

탐지대상

업로드된 파일 내용물에 <?php 태그가 있는지 검사

파일 내용을 검사하기 때문에, 확장자를 위조해도 탐지 가능
예) .jpg

```
blue@blue:~$ sudo tail -f -n 0 /var/log/apache2/modsec_audit.log | grep --line-b
uffered "Custom"
Message: Access denied with code 403 (phase 2). Pattern match "(?i:union\\s+sele
ct)" at ARGS:id. [file "/etc/modsecurity/fm8plus_custom.conf"] [line "1"] [id "2
000001"] [msg "FM8+ Custom SQL Injection Detected"]
Apache-Error: [file "apache2_util.c"] [line 275] [level 3] [client 192.168.10.1]
ModSecurity: Access denied with code 403 (phase 2). Pattern match "(?i:union\\
\\\\s+select)" at ARGS:id. [file "/etc/modsecurity/fm8plus_custom.conf"] [line
"1"] [id "2000001"] [msg "FM8+ Custom SQL Injection Detected"] [hostname "192.16
8.10.11"] [uri "/"] [unique_id "am_u19fTBwzjeBMalmznQAAAEY"]
Message: Access denied with code 403 (phase 2). Pattern match "<script" at ARGS:
content. [file "/etc/modsecurity/fm8plus_custom.conf"] [line "2"] [id "2000002"]
[msg "FM8+ Custom XSS Detected"]
Apache-Error: [file "apache2_util.c"] [line 275] [level 3] [client 192.168.10.1]
ModSecurity: Access denied with code 403 (phase 2). Pattern match "<script" at
ARGS:content. [file "/etc/modsecurity/fm8plus_custom.conf"] [line "2"] [id "2000
002"] [msg "FM8+ Custom XSS Detected"] [hostname "192.168.10.11"] [uri "/inquiry
.php"] [unique_id "am_vCMwqW4ttSAa06merAAAAAY"]
Message: Access denied with code 403 (phase 2). Pattern match "\\..php$" at FILES:
file. [file "/etc/modsecurity/fm8plus_custom.conf"] [line "3"] [id "2000003"] [
msg "FM8+ Custom Webshell Upload Detected"]
Apache-Error: [file "apache2_util.c"] [line 275] [level 3] [client 192.168.10.1]
ModSecurity: Access denied with code 403 (phase 2). Pattern match "\\..php
$" at FILES:file. [file "/etc/modsecurity/fm8plus_custom.conf"] [line "3"] [id "
2000003"] [msg "FM8+ Custom Webshell Upload Detected"] [hostname "192.168.10.11"]
[uri "/upload.php"] [unique_id "am_v19fTBwzjeBMalmznGAAAEg"]
tail: /var/log/apache2/modsec_audit.log: file truncated
```

공격별 탐지 결과

SQL Injection, XSS, WebShell 모두 403 차단 성공

실시간 로그 확인 프로세스

실시간 감시로 403 차단 및 Rule ID 기록 확인

Audit Log 기록 내용

차단 시각, 공격 유형, Rule ID, 요청 정보 Audit Log 저장

3

Custom Rules

3

403 차단 건수

100%

탐지 성공률

※ 자세한 내용은 기업 정보 보호 점검 보고서 확인 부탁드립니다.



기업 정보보호 점검 결과 | SIEM



[공격 1] 포트 스캔 (Nmap) - 방화벽/네트워크 침투 탐지 검증

공격 목적

- 대상 서버의 주요 포트 탐색
- 서비스 정보 수집(Reconnaissance)

공격 명령어

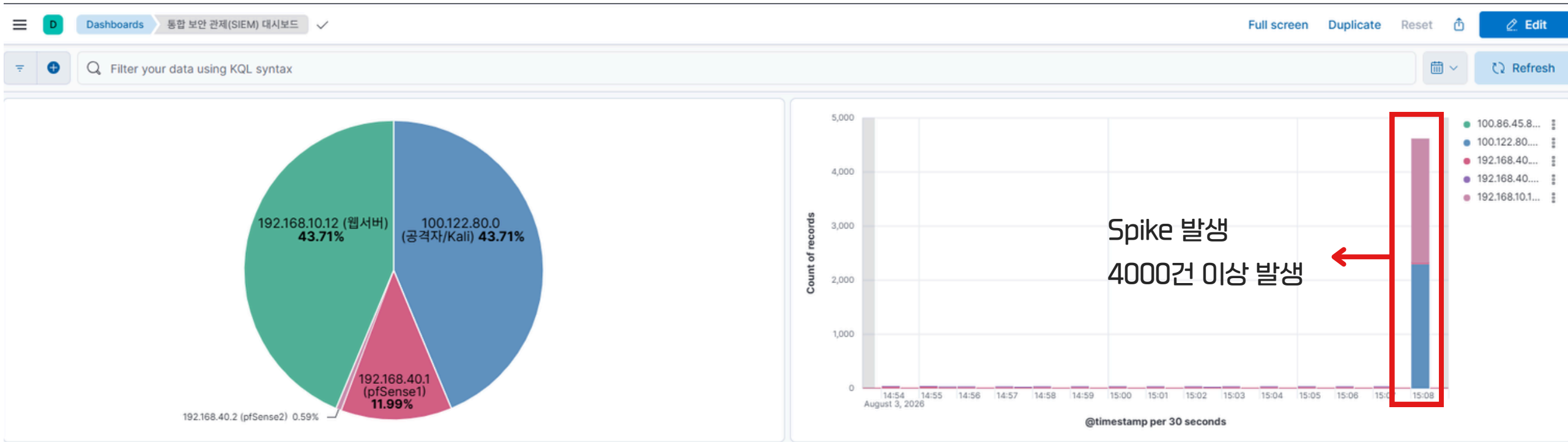
- `nmap -p 80,443,8080 --script=http-enum 192.168.10.12`

공격 대상

- 192.168.10.12

공격 시각

- 2026.07.31 15:08



항목	내용
이상 징후	30초 단위 트래픽 급증(Spike, 약 4,600건 돌파)
탐지 위치	Gateway Traffic Dashboard
분석 결과	Reconnaissance(포트 스캔) 행위 탐지

기업 정보보호 점검 결과 | SIEM

[공격 2] 웹 취약점 스캔 (Nikto) - WAF/웹로그 탐지 검증

공격 목적

- 웹 서버 취약점 자동 탐색
- 웹 서버 보안 설정 점검

공격 명령어

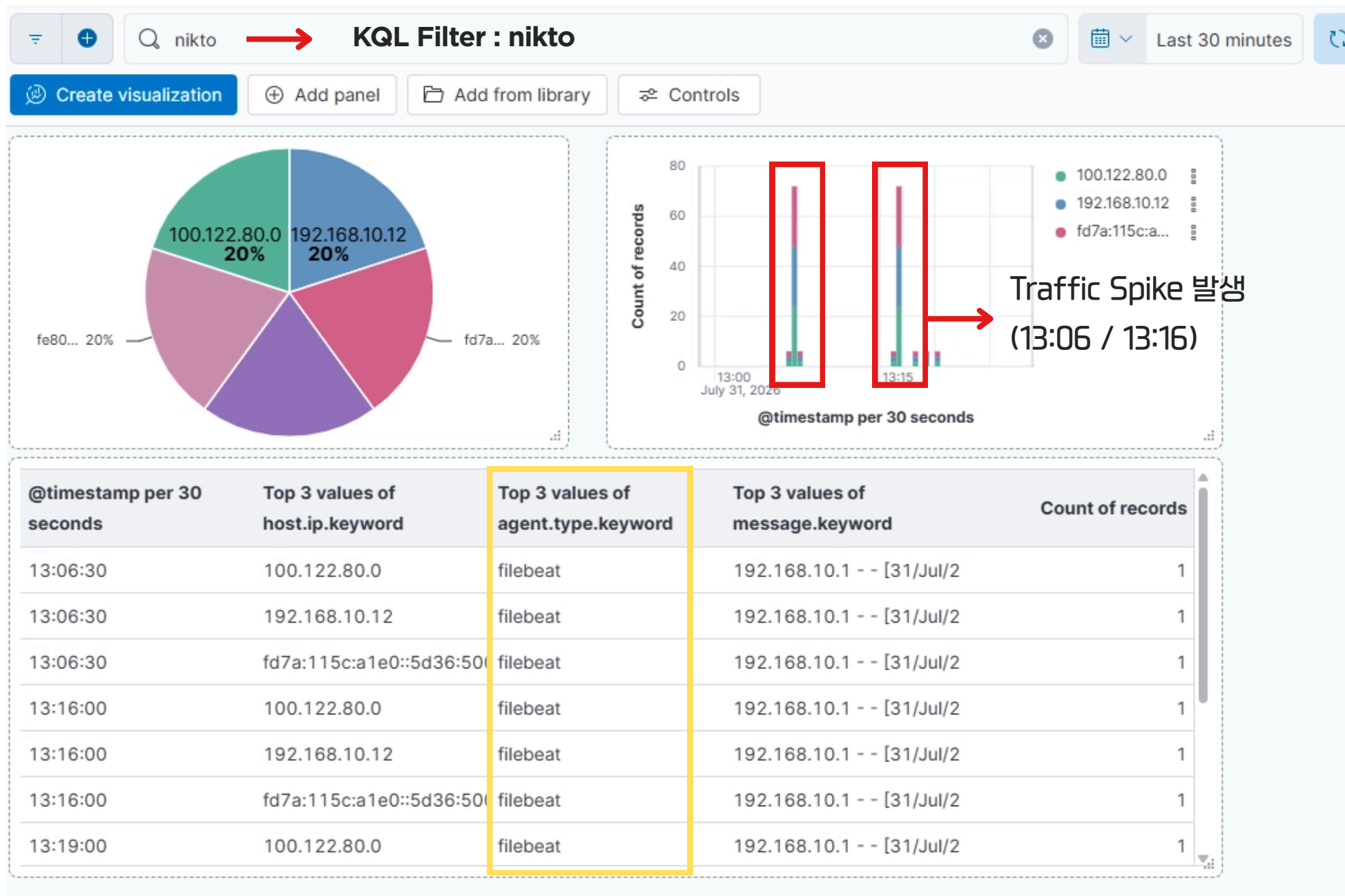
- nikto -h http://192.168.10.12

공격 대상

- 192.168.10.12

수집 로그

- Filebeat Apache Access Log



결과

Nikto 웹 취약점 스캔 수행 시 Apache Access Log가 Filebeat를 통해 SIEM으로 수집되었으며, 특정 시점(13:06, 13:16)에 트래픽 급증(Spike)과 반복적인 웹 요청 패턴을 기반으로 자동화된 웹 취약점 스캔 행위를 탐지하였다.



기업 정보보호 점검 결과 | SIEM



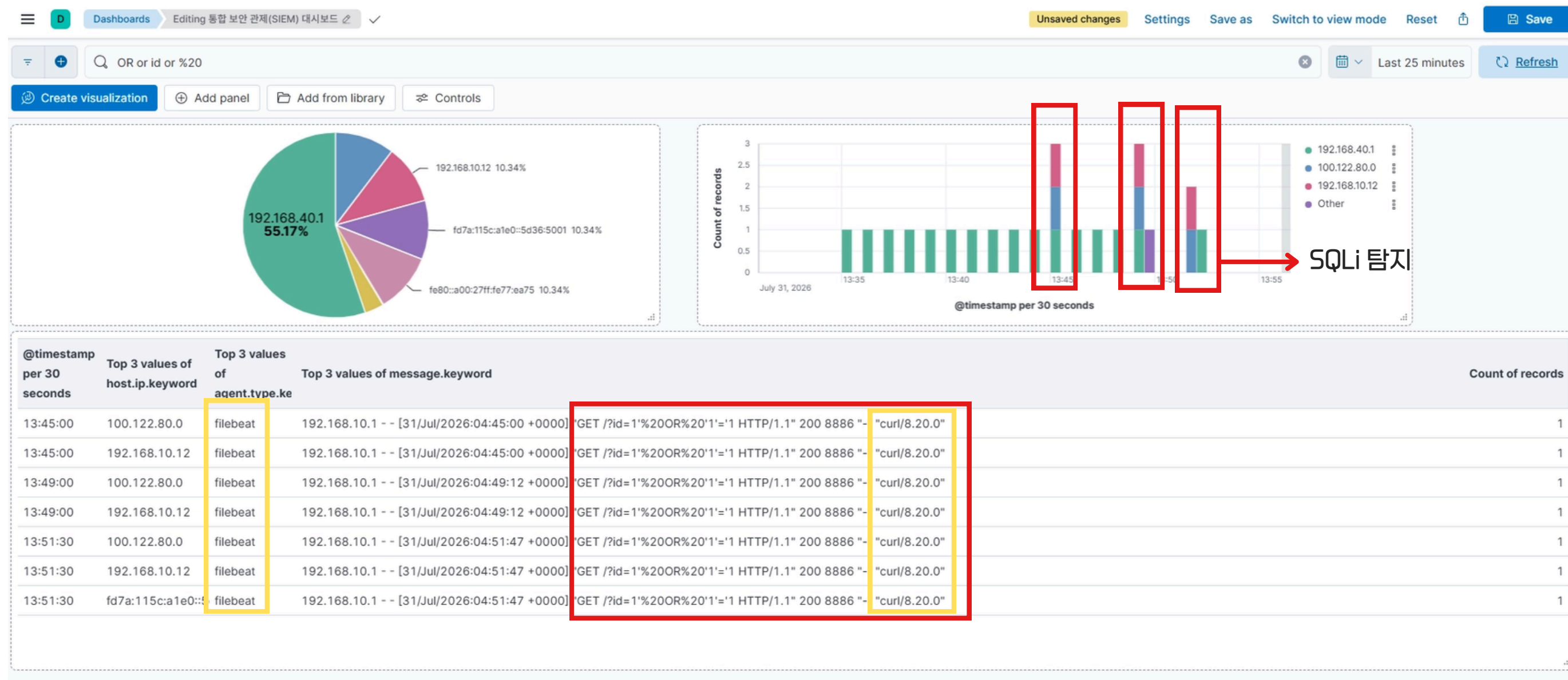
[공격 3] 웹 애플리케이션 공격 (SQL Injection) - Web/WAF 탐지 검증

공격 목적

- SQL Injection 취약점 검증
- URL Query 조작

공격 명령어

- curl "http://192.168.10.12/?id=1'%20OR%20'1'='1"



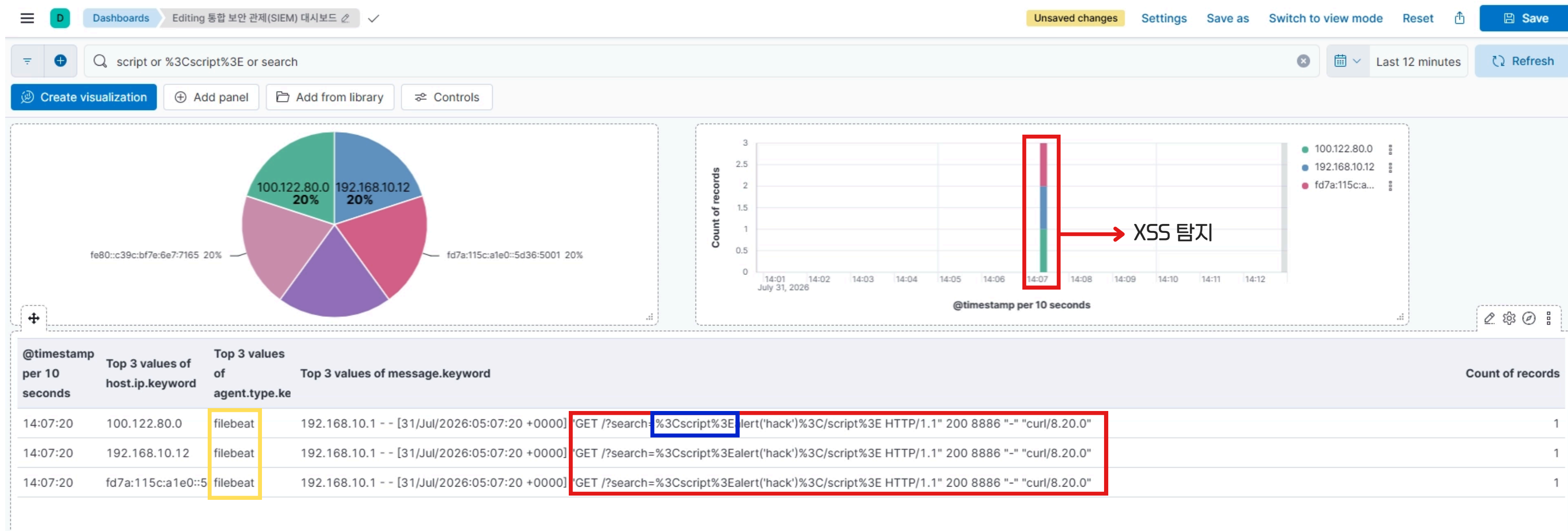
[공격 4] 웹 애플리케이션 공격 (XSS) - Web/WAF 탐지 검증

공격 목적

- Reflected XSS 검증
- Script Injection 탐지

공격 명령어

- curl "http://192.168.10.12/?search=%3Cscript%3Ealert('hack')%3C/script%3E"





기업 정보보호 점검 결과 | SIEM



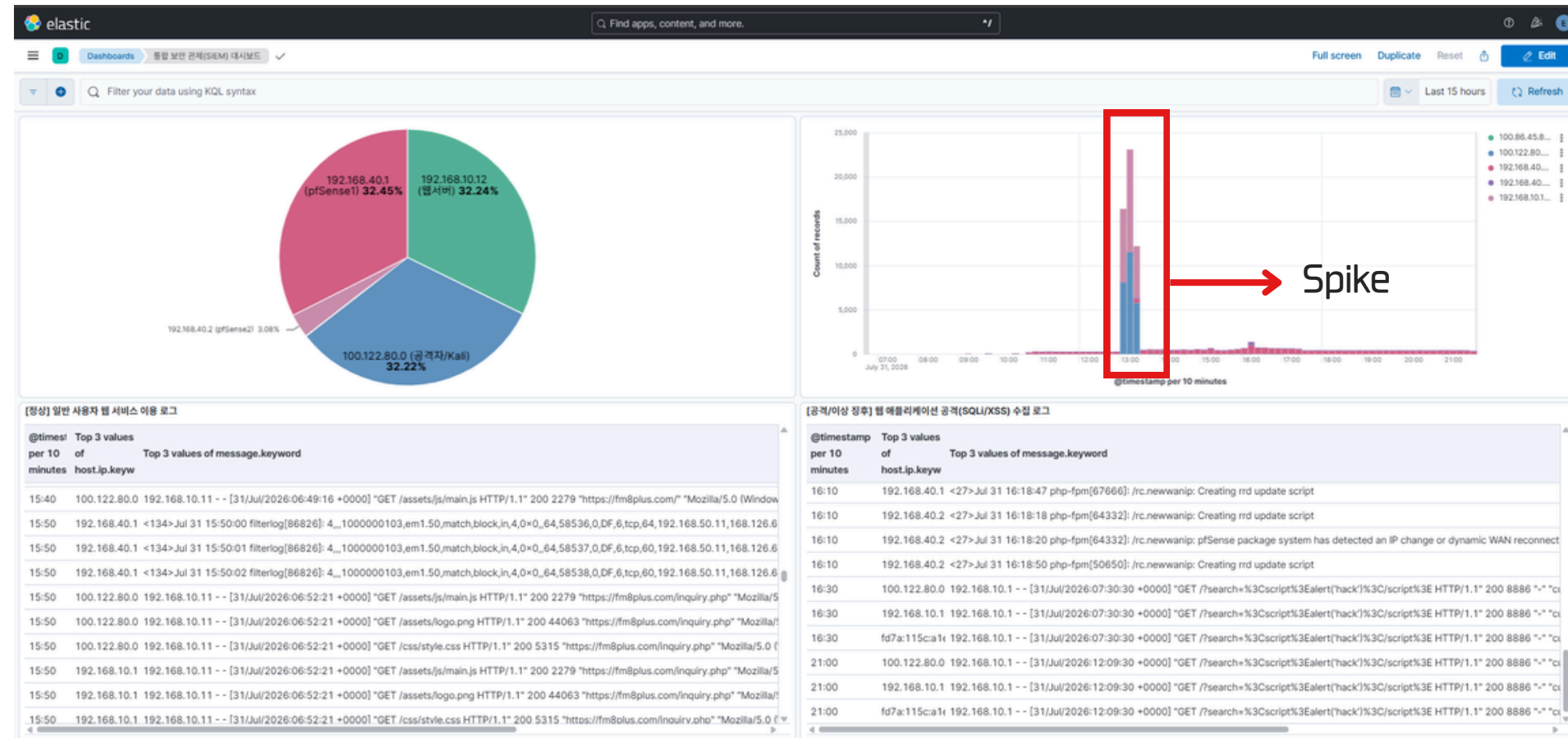
SIEM 정상/공격 트래픽 비교 분석

비교 목적

- 정상 이용자와 공격 로그 비교
- SIEM 이상징후 탐지 검증
- 공격 패턴 식별 가능 여부 확인

비교 항목

- 요청 URL
- User-Agent
- 요청 패턴
- 트래픽 발생량
- SIEM 탐지 결과



※ SIEM 통합 대시보드에서 정상 사용자 로그와 공격 로그를 동시에 모니터링

[정상] 일반 사용자 웹 서비스 이용 로그				[공격/이상 징후] 웹 애플리케이션 공격(SQLi/XSS) 수집 로그			
@timestamp per 10 minutes	Top 3 values of host.ip.keyw	Top 3 values of message.keyword	정상로그	@timestamp per 10 minutes	Top 3 values of host.ip.keyw	Top 3 values of message.keyword	공격로그
15:40	100.122.80.0	192.168.10.11	GET /assets/js/main.js HTTP/1.1	16:10	192.168.40.1	192.168.10.11	php-fpm[67666]: /rc.newwanip: Creating rrd update script
15:50	192.168.40.1	192.168.10.12	filterlog[86826]: 4,,,1000000103,em1.50,match,block,in,4,0,0,64,58536,0,DF,6,tcp,64,192.168.50.11,168.126.6	16:10	192.168.40.2	192.168.10.11	php-fpm[64332]: /rc.newwanip: Creating rrd update script
15:50	192.168.40.1	192.168.10.11	filterlog[86826]: 4,,,1000000103,em1.50,match,block,in,4,0,0,64,58537,0,DF,6,tcp,60,192.168.50.11,168.126.6	16:10	192.168.40.2	192.168.10.11	php-fpm[64332]: /rc.newwanip: pfSense package system has detected an IP change or dynamic WAN reconnect
15:50	192.168.40.1	192.168.10.11	filterlog[86826]: 4,,,1000000103,em1.50,match,block,in,4,0,0,64,58538,0,DF,6,tcp,60,192.168.50.11,168.126.6	16:10	192.168.40.2	192.168.10.11	php-fpm[50650]: /rc.newwanip: Creating rrd update script
15:50	100.122.80.0	192.168.10.11	GET /assets/js/main.js HTTP/1.1	16:30	100.122.80.0	192.168.10.1	GET /?search=%3Cscript%3Ealert('hack')%3C/script%3E HTTP/1.1
15:50	100.122.80.0	192.168.10.11	GET /assets/logo.png HTTP/1.1	16:30	192.168.10.1	192.168.10.1	GET /?search=%3Cscript%3Ealert('hack')%3C/script%3E HTTP/1.1
15:50	100.122.80.0	192.168.10.11	GET /css/style.css HTTP/1.1	16:30	fd7a:115c:a1e	192.168.10.1	GET /?search=%3Cscript%3Ealert('hack')%3C/script%3E HTTP/1.1
15:50	192.168.10.1	192.168.10.11	GET /assets/js/main.js HTTP/1.1	21:00	100.122.80.0	192.168.10.1	GET /?search=%3Cscript%3Ealert('hack')%3C/script%3E HTTP/1.1
15:50	192.168.10.1	192.168.10.11	GET /assets/logo.png HTTP/1.1	21:00	192.168.10.1	192.168.10.1	GET /?search=%3Cscript%3Ealert('hack')%3C/script%3E HTTP/1.1
15:50	192.168.10.1	192.168.10.11	GET /css/style.css HTTP/1.1	21:00	fd7a:115c:a1e	192.168.10.1	GET /?search=%3Cscript%3Ealert('hack')%3C/script%3E HTTP/1.1

결과

- ✓ 정상 웹 요청 및 브라우저 User-Agent 확인
- ✓ SQLi/XSS Payload 및 curl·Nikto User-Agent 식별
- ✓ 정상/공격 로그 실시간 분리 및 시각화
- ✓ 공격 시점·IP·Payload 즉시 확인 가능

DB 백업 및 PITR 기반 장애 복구 체계

1

DB 백업 서버 구축

VLAN 분리 · ForceCommand 접근 통제

2

자동 백업 및 PITR

mysqldump · Binlog 15분 동기화

3

장애 발생 및 복구

시점 복구(PITR) 동작 검증

4

ForceCommand 효과

백업 서버 침해 시 백업 삭제 차단



DB 백업 및 PITR 기반 장애 복구 체계



① DB 백업 서버 구축

구축 목적

- DB 서버와 분리된 백업 저장소 구축
- 장애 발생 시 신속한 복구
- 최소 권한 원칙 적용

네트워크 구성

- VLAN50
- DB Server
 - ↓ SSH(22)
- DB Backup Server

주요 기능

- ✓ Full Backup
- ✓ Binlog(PITR)
- ✓ SSH Key 인증
- ✓ ForceCommand(rrsync)

```
network:
  version: 2
  ethernet:
    enp0s3:
      dhcp4: false
      optional: true
  vlans:
    enp0s3.50:
      id: 50
      link: enp0s3
      addresses: [192.168.50.11/26]
      routes:
        - to: default
          via: 192.168.50.1
      nameservers:
        addresses: [168.126.63.1, 168.126.63.2]
```

* Netplan 설정을 통해 백업 서버를 VLAN50(192.168.50.11/26)으로 구성

```
blue@db-backup:~$ cat ~/.ssh/authorized_keys
command="/usr/bin/rrsync db backups/",no-port-forwarding,no-X11-forwarding,no-agent-forwarding,no-pty ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAIEXWoc8h961yf70TxwD0cx
```

* ForceCommand(rrsync) 적용

결과

- ✓ DB 백업 서버 별도 VLAN 분리
- ✓ ForceCommand 적용으로 rsync만 허용
- ✓ 백업 데이터 무결성 및 접근 통제 강화

DB 백업 및 PITR 기반 장애 복구 체계

② 자동 백업 및 PITR

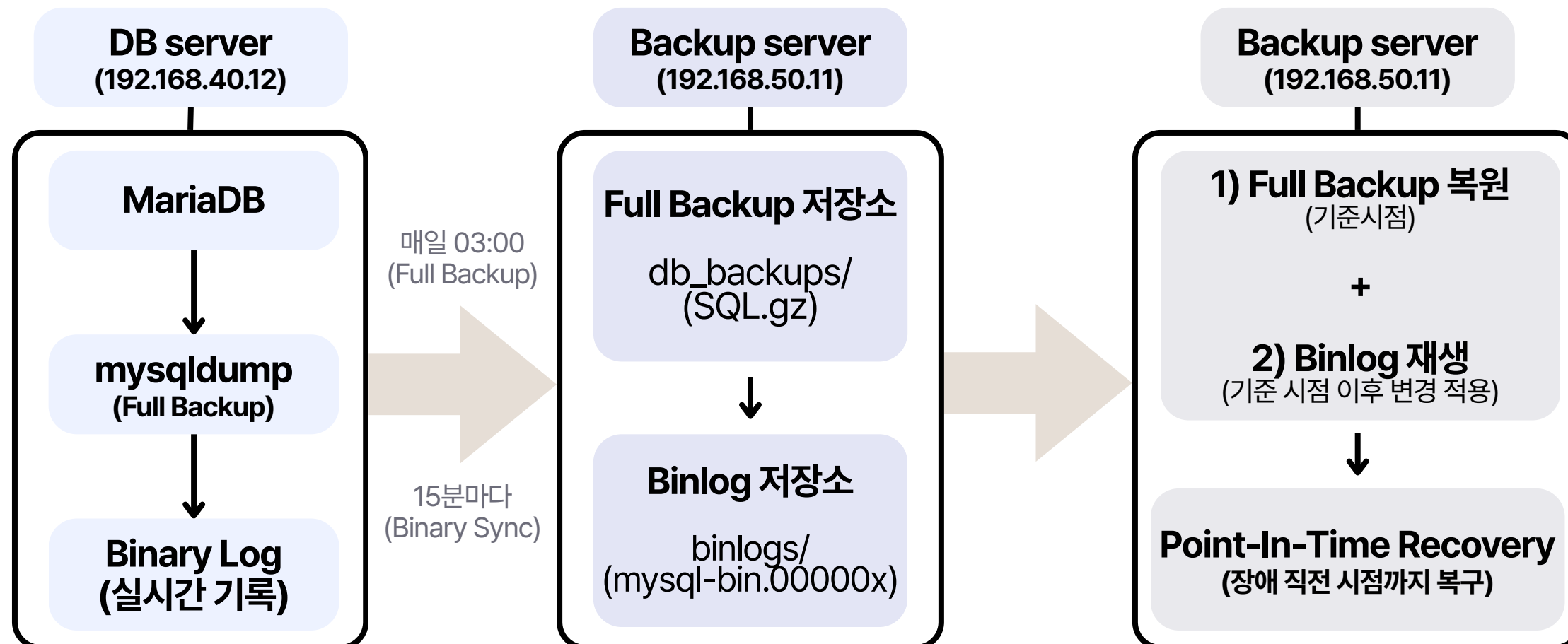
```
blue@db-server:~$ cat /usr/local/bin/db_backup.sh
#!/bin/bash
BACKUP_DIR=/home/blue/backups
DATE=$(date +%Y%m%d_%H%M%S)
FILE="fm8plus_${DATE}.sql"

sudo mysqldump fm8plus > "${BACKUP_DIR}/${FILE}"
gzip "${BACKUP_DIR}/${FILE}"

rsync -avz -e "ssh -o StrictHostKeyChecking=accept-new"
z" blue@192.168.50.11:

find "${BACKUP_DIR}" -name '*.sql.gz' -mtime +7 -delete
```

※ mysqldump → gzip → rsync → Backup Server



```
blue@db-server:~$ crontab -l
0 3 * * * /usr/local/bin/db_backup.sh >> /home/blue/backups/backup.log 2>&1
```

※ 매일 새벽 03:00에 전체 백업 실행

```
*/15 * * * * /usr/local/bin/binlog_sync.sh >> /home/blue/backups/binlog_sync.log
2>&1
```

※ 15분마다 Binary Log 동기화

```
blue@db-server:~$ sudo mysql -e "SHOW BINARY LOGS;"
+-----+-----+
| Log_name          | File_size |
+-----+-----+
| mysql-bin.000001  | 328       |
+-----+-----+
```

※ Binlog 확인 (DB Server)

```
blue@db-backup:~$ ls -la --time-style=full-iso ~/db_backups/binlogs
total 16
drwxr-xr-x 2 blue blue 4096 2026-07-31 05:35:29.672883129 +0000 .
drwxrwxr-x 3 blue blue 4096 2026-07-31 06:15:47.703527273 +0000 ..
-rw-rw---- 1 blue blue 328 2026-07-31 05:35:29.664883151 +0000 mys
```

DB Server의 Binlog 파일이 15분마다 정상 동기화

※ Binlog 동기화 결과(Backup Server)

```
blue@db-server:~$ ls -la ~/backups/
total 44
drwxrwxr-x 2 blue blue 4096 Jul 31 06:15 .
drwxr-x--- 5 blue blue 4096 Jul 31 05:11 ..
-rw-rw-r-- 1 blue blue 351 Jul 31 06:15 binlog_sync.log
-rw-rw-r-- 1 blue blue 4194 Jul 31 05:12 fm8plus_20260731_051217.
-rw-rw-r-- 1 blue blue 4195 Jul 31 05:30 fm8plus_20260731_053053.
-rw-rw-r-- 1 blue blue 4199 Jul 31 05:43 fm8plus_20260731_054326.
-rw-rw-r-- 1 blue blue 4198 Jul 31 06:15 fm8plus_20260731_061548.
```

※ 백업 파일 확인 (Backup Server)

DB 백업 및 PITR 기반 장애 복구 체계

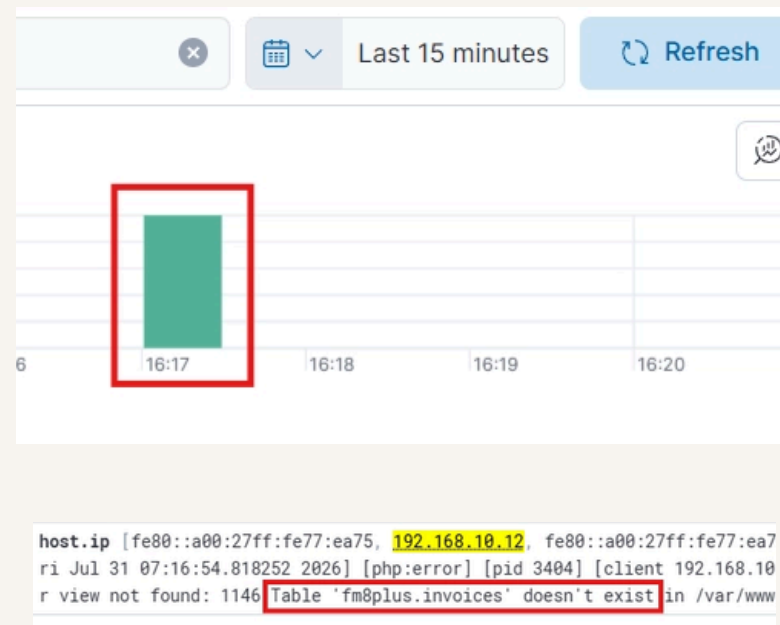
③ 장애 발생 및 탐지

1. 공격으로 인한 DB 장애 발생



- 공격자가 DB서버에 침투하여 테이블 삭제
- 웹 서비스 500 에러 발생

2. SIEM 알림 확인



- SIEM(Kibana)에서 DB 오류 로그 급증 확인

3. 백업 파일로 복구 수행

1) 백업 파일 복사 및 압축 해제

```
scp -o PubkeyAuthentication=no
blue@192.168.50.11:db_backups/fm8plus_20260731_061548.sql.gz /home/blue/
gunzip -k fm8plus_20260731_061548.sql.gz
```

2) DB 복원

```
sudo mysql fm8plus <
fm8plus_20260731_061548.sql
```

(참고) binlog 재생 명령 (필요 시)

```
MYSQLBINLOG --START-DATETIME="2026-07-31
06:15:00" --STOP-DATETIME="2026-07-31
07:15:59" MYSQL-BIN.000001 | MYSQL FM8PLUS
```

- 백업 서버의 최신 Full Backup 파일을 가져와 복원
- (필요 시) binlog 재생으로 장애 직전 시점까지 복구

4. 복구 결과 확인

```
blue@db-server:~$ sudo mysql fm8plus -e "SELECT * FROM invoices;"
+----+-----+-----+-----+-----+
| id | subscription_id | period_start | period_end | due_date |
+----+-----+-----+-----+-----+
| 1 | 1 | 2026-07-01 | 2026-07-31 | 2026-08-26 |
+----+-----+-----+-----+-----+
```

요금 납부	
FM 소렌티스 고객님의 이번 달 청구 내역을 확인하세요.	
청구 기간	7월 1일 - 7월 31일
이번 달 청구 금액	55,500원
납부 기한 (2026년 8월 26일)	
납부하기	
청구 상세	
기본료 (FM 소렌티스)	48,000원
부가서비스 (FM Studio Pro 월료)	3,000원
데이터 추가 사용	5,500원
멤버십 할인	-2,000원
합계	55,500원

- 삭제되었던 테이블과 데이터 정상 복구
- 웹 서비스 정상 작동 재개

결과

DB서버가 공격당해도
백업 데이터를 이용해 신속 복구 가능

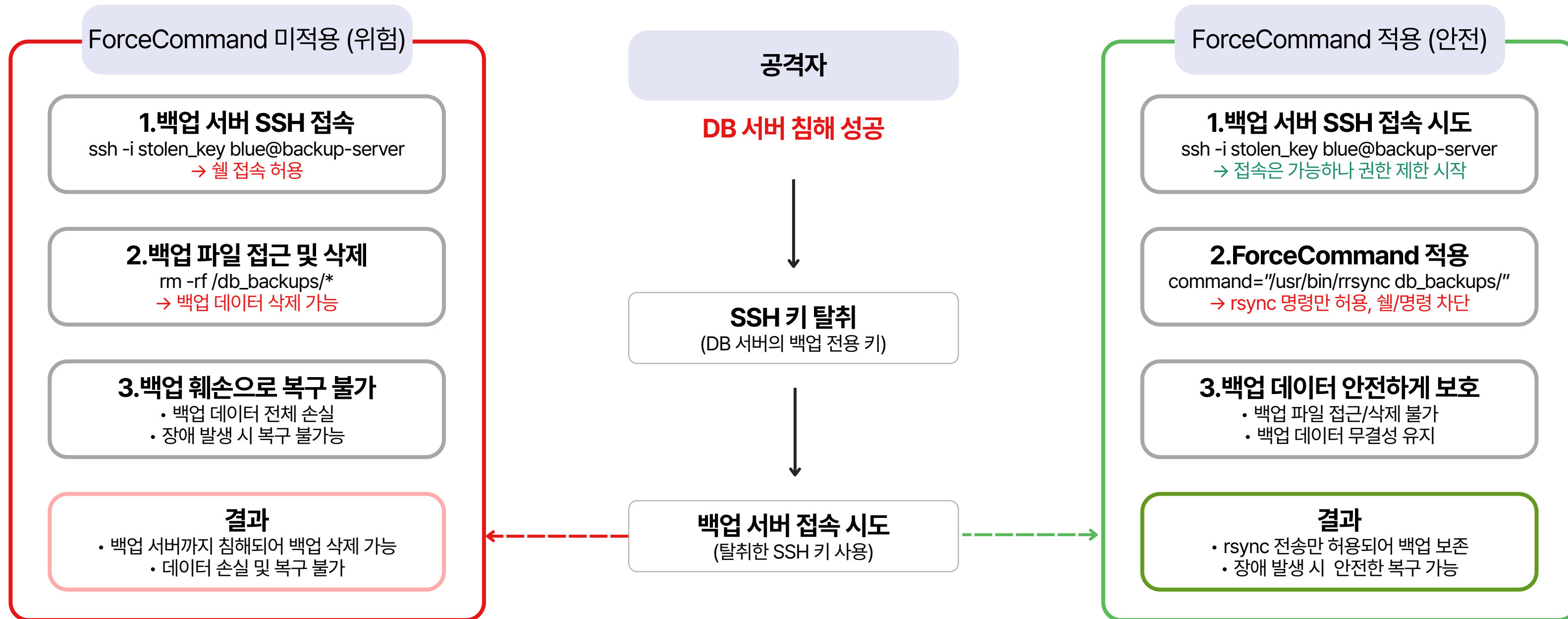
Full Backup + Binlog 기반
PITR(시점 복구) 체계 동작 검증

장애 발생 ~ 복구 전 과정을
SIEM 로그로 확인 가능

서비스 가용성과 데이터 무결성 확보

DB 백업 및 PITR 기반 장애 복구 체계

④ ForceCommand 효과



```
blue@db-backup:~$ cat ~/.ssh/authorized_keys
command="/usr/bin/rrsync db backups/",no-port-forwarding,no-X11-forwarding,no-agent-forwarding,no-pty ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAIEXWoc8h961yf70TxwD0cx
```

※ command 옵션 확인

```
blue@db-server:~$ ssh blue@192.168.50.11
PTY allocation request failed on channel 0
/usr/bin/rrsync error: Not invoked via sshd
Connection to 192.168.50.11 closed.
```

※ 쉘 접속 차단 테스트 결과



DB 백업 및 PITR 기반 장애 복구 체계



⑤결과



구분	구축 전	구축 후
백업	수동	자동
백업 위치	DB서버	분리된 Backup Server
복구	불가능	Full Backup + PITR
장애 탐지	수동 확인	SIEM 실시간 탐지
백업 보호	없음	ForceCommand
서비스	장애 지속	신속 복구

구현 완료

- ✓ Nmap 탐지
- ✓ Nikto 탐지
- ✓ SQL Injection 탐지
- ✓ XSS 탐지
- ✓ DB Backup
- ✓ PITR
- ✓ ForceCommand

기대 효과

- 서비스 연속성 확보
- 데이터 무결성 확보
- 공격 대응 능력 향상
- 운영 안정성 향상

10

자체 평가 의견

1

완성도 평가

목표 대비 달성도

2

잘한 점 · 아쉬운 점

성과 및 개선 사항

3

향후 발전 방향

커널 · 시스템콜 레벨 심화 과제

4

소감 및 경험

3차 프로젝트 소감 및 경험



자체 평가 의견



프로젝트 완성도 평가

실제 인프라 기반 구축

이론이 아닌, 실제로 동작하는 인프라 위에서 검증
가상 시나리오나 다이어그램으로 끝내지 않고, pfSense 이중화·VLAN 분리·WAF·SIEM까지 실제로 동작하는 서버 환경을 처음부터 직접 구축했고, 그 환경에 진짜 공격을 날려서 로그로 결과를 확인하는 과정을 전부 실습

실증 기반 검증

"이론상 이렇게 막힌다"가 아니라 "실제로 이렇게 막히는 걸 우리 눈으로 확인했다"는 점에서 완성도가 높음

잘한점 및 성과

계층 간 연동 검증

Suricata·WAF의 탐지·차단, SIEM의 로그 통합, DB 백업·PITR의 사후 복구까지 — 각 계층이 따로 노는 게 아니라 하나의 대응 파이프라인으로 실제 연동되는 걸 검증

엔드투엔드 재현

이렇게 공격→탐지→차단→로그→복구까지 End to End로 직접 재현

아쉬운점 및 개선사항

부족했던 점

시그니처 기반 자동 경보 시스템 구축:
대시보드를 통한 트래픽 피크 (Spike) 시각화 및 KQL 수동 검색 중심의 검증으로 진행되어, 공격 발생 시 관제 담당자에게 즉각 통보되는 SIEM 경보 (Alert) 시스템 구축까지는 다루지 못했음

기술적 개선 사항

NIFTY/Sigma Rule 기반 웹 공격 자동 탐지 룰 등록:
단순히 키워드 검색(script, OR)에 의존하지 않고, URL 인코딩 변형 및 WAF 우회 기법에 대응할 수 있도록 정규표현식 기반의 Elasticsearch Detection Rule 등록



향후 발전 방향

지금까지 구축한 보안 설정은 서버 간 접근 권한을 막는 방어입니다.

하지만 **BPFDoor** 같은 악성코드는 이미 서버 안에 들어온 뒤 리눅스 커널 깊숙한 곳에 숨어서 **방화벽 규칙을 우회**하는 방식이라, 운영체제 깊은 곳을 들여다보는 별도의 전문 도구가 필요합니다.

이 도구들은 **커널/시스템콜 레벨**의 심화 지식이 필요해서 **향후 과제**로 진행할 예정입니다.

SOAR (보안 자동화 및 대응) 연동 학습:

SIEM에서 XSS나 SQLi 공격을 탐지했을 때, 공격자 IP를 방화벽 차단 정책에 자동으로 등록하는 자동 대응(Playbook) 시나리오 연구를 목표로 했습니다

SOC 관제 룰(Rule) 고도화 및 False Positive(오탐) 정제:

정상적인 웹 사용자의 검색어 입력(예: script 단어가 포함된 게시물 검색)이 XSS 공격으로 오탐되지 않도록 필터링 예외 처리 조건 학습 할 예정입니다

MITRE ATT&CK 프레임워크 매핑:

수집된 로그 및 탐지 규칙을 MITRE ATT&CK Matrix에 매핑하여 체계적인 위협 대응 체계 구축하였습니다

소감 및 경험

구축과 검증의 차이

"만드는 것"과 "그게 진짜 되는지 확인하는 것"은 완전히 다른 작업이라는 걸 체감했습니다. 룰을 저장해도 실제 파일엔 반영이 안 되어 있거나, WAF가 켜져있다고 생각했는데 실제로론 꺼져있던 경험처럼, 눈에 보이는 상태와 실제 동작 상태가 다를 수 있다는 걸 직접 겪으며 배웠습니다.

스스로 의심하고 재검증

체계를 다 만든 뒤에도 "이게 정말 의도한 대로 안전한가"를 스스로 재점검하다가, 백업 계정과 복구 계정이 실제로는 분리돼있지 않다는 허점을 뒤늦게 발견해 개선했습니다. 완성했다고 끝이 아니라, 의심하고 검증하는 과정 자체가 보안이라는 걸 느꼈습니다.

팀 협업 경험

비대면 수업이지만 테일스케일 같은 원격 접속 도구를 사용해서 팀원들과 같이 서버를 구축하고 매핑이 꼬이거나 설정이 어긋나는 등 혼자서는 해결하기 힘든 유형의 문제들을 함께 풀어나가는 경험도 이번 프로젝트에서 얻은 큰 자산이었습니다.

🔍 FM 8+



감사합니다

팔로팔로미

김혜미, 조경익, 김유선, 이찬근, 정슬기